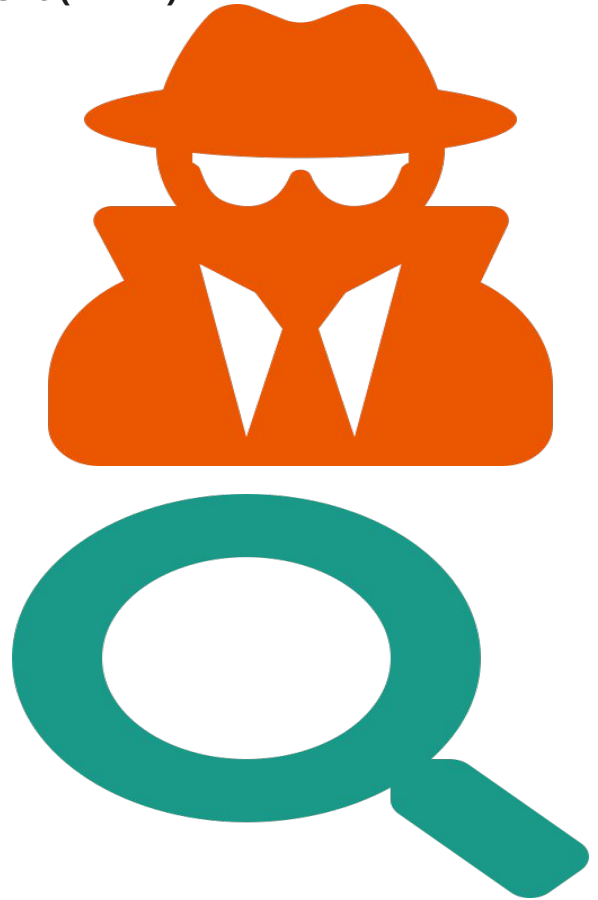


Threat Thinking


*Session 2 - Attackers, STRIDE, ATT&CK & Trust
Boundaries*



Module Learning Outcomes



LO1

Evaluate a range of encryption and authentication methods for a given set of requirements.

LO2

Evaluate different approaches to assessing a system's security and use these to evaluate the security of a system.

LO3

Utilise systematic knowledge to create secure environments at the host or network level.

LO4

Develop and evaluate software that addresses the most common and most severe security concerns.

Session 2 addresses LO2. LO1, LO3, and LO4 are progressively addressed across Sessions 3-12.

KEY CONCEPT



You cannot design a defence before you understand what you are defending against

Session 2 establishes the attacker's perspective before any defence is studied. Every control in Sessions 3 to 7 exists to counter a threat category you will identify here. The threat comes first - the control follows from it.



Threat Actors - Who Is the Attacker?

Criminal Financial motivation - ransomware, data theft, fraud. Targets high-value assets and payment systems.

Nation-State Espionage, disruption, persistent access. Highly resourced, long time horizons, difficult to attribute.

Insider Access already granted. Motivated by grievance, coercion, or negligence. Hardest actor to detect.

Opportunist Automated scanning. No specific target. Exploits known, unpatched vulnerabilities at scale.

Analogy

Think of a bank: the criminal wants the vault, the nation-state wants the records room, the insider already has a key, and the opportunist tries every door handle looking for one that is unlocked.

Motivation shapes which assets are targeted and which methods are chosen.

The Attack Surface



- Every exposed service, open port, and accepted input is part of the attack surface.
- Wider attack surface = more entry points = more opportunity for every attacker type.
- Reducing attack surface: remove unnecessary services, close unused ports, minimise exposed functions. Every component removed is an attack vector eliminated.
- The relationship: exposed entry point + attacker motivation = threat to a specific security property.

The goal is not zero attack surface - that would mean no system. The goal is minimum viable attack surface for the required function.



STRIDE - From Threat to Property



STRIDE - A Two-Way Lookup



- STRIDE classifies threats into six categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.
- Session 1 established the five security properties. STRIDE names the threats that violate each of them.
- The lookup works in both directions:
- Given a threat - name the property it violates
- Given a property - name the threat class that attacks it
- This two-way fluency is what threat modelling in coursework Part B requires.

Analogy

Think of STRIDE and the five properties as two sides of the same coin. You can ask "which threat is this?" and map to a property - or ask "which properties are at risk?" and map back to threat categories.

This two-way fluency is what threat modelling requires in practice.

STRIDE - Mapped to the Five Properties



STRIDE Threat	What It Means	Property Violated
Spoofing	Impersonating another user, system, or component	Authenticity
Tampering	Modifying data or code without authorisation	Integrity
Repudiation	Denying an action when no audit trail exists to disprove it	Accountability
Information Disclosure	Exposing information to parties not authorised to see it	Confidentiality
Denial of Service	Making a system unavailable to legitimate users	Availability
Elevation of Privilege	Gaining capabilities or permissions beyond what was authorised	Authenticity + Accountability

Elevation of Privilege - The Nuanced Case



- EoP defined: gaining capabilities or permissions beyond what was explicitly authorised.
- Authenticity failure: the system can no longer trust the entity is who it believes it to be. An attacker acting under a compromised service account is not the authenticated service - Authenticity is violated.
- Accountability failure: when a high-privilege action is performed under a stolen or elevated identity, all audit log entries are attributed to the wrong actor. No one can determine who did what, when, or whether it was authorised.
- Why not just one property: Authenticity asks who is this entity? Accountability asks who performed that action? EoP breaks both simultaneously. CIA alone names neither.



Trust Boundaries



What Are Trust Boundaries?



- A trust boundary marks the point where the level of trust changes between components, zones, or principals.
- On an architecture diagram: a boundary separates components that share the same trust level from those that do not.
- Examples: public internet vs DMZ, DMZ vs internal network, internal app vs database, browser vs web server.
- Assessment requirement A2 (7%): draw trust boundaries on your architecture diagram and label each zone.

Analogy

Think of airport security zones. Airside and landside operate under different trust levels. Everything crossing the boundary - people, luggage, data - must be inspected and authorised.

The boundary is the checkpoint, not the barrier. The barrier is the enforcement mechanism.

Crossing a Trust Boundary



- Every crossing must be authenticated: is this entity who it claims to be? This enforces the Authenticity property at the boundary.
- Every crossing must be authorised: is this entity permitted to cross here, with this request, at this time?
- Data arriving from a lower-trust zone must be treated as untrusted until validated - regardless of what the sender claims about it.
- Unenforced trust boundaries are the most common lateral movement path: an attacker enters at a low-trust entry point and traverses unguarded boundaries to reach high-value targets. Most real breaches involve this pattern.

KEY CONCEPT

**Every trust boundary is a decision.
Either the system enforces it, or an
attacker exploits the absence.**

Unenforced trust boundaries do not disappear - they become unguarded paths. Drawing the boundary on a diagram is not the control. Enforcing it in the architecture is. This distinction is what separates a design from a security design. It is also what Part B is assessed on.



MITRE ATT&CK



MITRE ATT&CK - A Reference Taxonomy



- ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge): a publicly available knowledge base of real-world attacker behaviour, maintained by MITRE.
- Purpose: maps from attacker goals (tactics) to specific methods (techniques) to what defenders can deploy (mitigations).
- Not a memorisation task. ATT&CK is a lookup tool for identifying realistic techniques for your domain and the mitigations that apply.
- Scope: Enterprise ATT&CK covers tactics from Initial Access through to Impact - the full lifecycle of a real attack.

Access ATT&CK at attack.mitre.org - used as a reference throughout this module, not as a list to memorise.

Reading ATT&CK - Tactic, Technique, Mitigation



- Tactic: the attacker's high-level goal - for example, Credential Access, Lateral Movement, or Exfiltration.
- Technique: a specific method used to achieve the tactic - for example, Brute Force (T1110) under Credential Access.
- Mitigation: what a defender deploys or configures to counter that specific technique.
- Reading a technique entry: name, description, affected platforms, example procedures, and the mitigations column. The mitigations column is the most useful column for your coursework.

Note

Mitigations in ATT&CK are names for controls - not explanations of how they work.

Sessions 3-7 teach you what those controls actually do and why they work.

For now: read the mitigation name and note that it exists. You will learn its mechanism in a later session.

Your Domain in ATT&CK



Recall your assigned domain (student index mod 6):

0 - Banking 1 - Healthcare 2 - Transport / Aviation
3 - Education 4 - Ecommerce / Retail 5 - Hospitality

- Open attack.mitre.org/navigator and explore the Enterprise ATT&CK matrix.
- Find 2 techniques a realistic attacker would use against your domain.
- For each: read the attacker goal, technique description, and listed mitigations.
- This feeds directly into your A3 threat entry. You will expand it in the lab.

10 Minutes Do This Now

Record:

- **Attacker goal (tactic)**
- **Technique name and ID**
- **What the mitigation says**

You will expand this in the lab.

Activity - Architecture Diagram Analysis

Step 1 On the architecture diagram (next slide), identify where the trust boundaries fall. Draw them.

Step 2 Apply STRIDE - identify at least one threat per category (6 threats minimum).

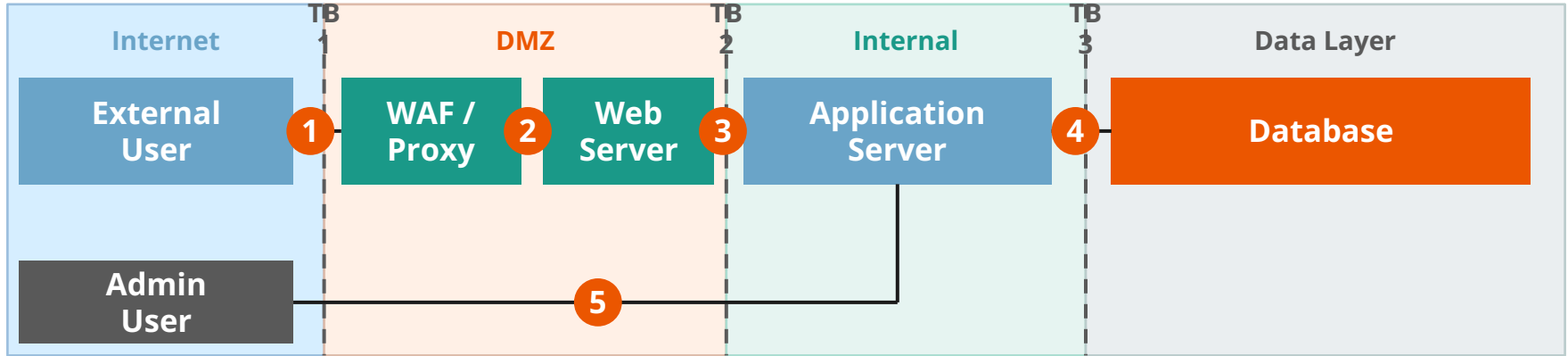
Step 3 Label each identified threat with the security property it violates.

Step 4 Groups compare: did any threat violate Authenticity or Accountability specifically? Would CIA alone have caught it?

Step 5 Discussion: which of these threats are realistic for your assigned domain?

45 minutes - Work in pairs. One STRIDE mapping per group, then compare across groups.

Web Application Architecture - Annotate This



Data Flow Key

- 1 HTTPS Request (External User - WAF) - crosses TB1
- 2 Filtered Traffic (WAF - Web Server) - within DMZ
- 3 App Request (Web Server - App Server) - crosses TB2
- 4 Database Query (App Server - Database) - crosses TB3
- 5 Admin Access (Admin User - App Server) - crosses TB1 and TB2

Discussion - Realistic vs Theoretical Threats

Look at the STRIDE threats you identified on the architecture diagram.

Which of these are realistic for your assigned domain - Banking, Healthcare, Transportation, Education, Ecommerce, or Hospitality?

What makes a threat realistic vs theoretical in a specific industry context?

Small Lab - MITRE ATT&CK Navigator

Step 1 Open attack.mitre.org/navigator in your browser.

Step 2 Recall your assigned domain. Select the Enterprise ATT&CK matrix.

Step 3 Find 2 techniques a realistic attacker would use against your domain. Use the search or scroll tactically.

Step 4 For each technique read: (a) the attacker goal, (b) the technique description, (c) the listed mitigations.

Step 5 Record using the structured format on the next slide.

Step 6 Be ready to share one finding with the group.

25 minutes - Individual, then share back with the group.

Lab Output - Structured Note Format



Record for each of your 2 ATT&CK techniques:

1. Domain: [your assigned domain]
2. Tactic (attacker goal): e.g. Credential Access
3. Technique name and ID: e.g. Brute Force (T1110)
4. What the attacker achieves if successful
5. Security property violated (from the extended CIA model)
6. Mitigations listed in ATT&CK

This structured note is the seed of your A3 threat entry. You will expand it into a full threat model finding in your coursework - adding business impact and the SRS security requirement that counters it.

Coursework Connections - A2 and A3



A2 - Architecture Diagram (7%)

- Draw the architecture of your assigned system.
- Mark all trust boundaries explicitly on the diagram.
- Label each zone: Internet, DMZ, Internal, Data Layer.
- The diagram is the diagrammatic foundation for your entire security apparatus analysis in Part B.

A3 - Key Risks and Reasoning (8%)

- Use STRIDE to identify threats relevant to your system.
- For each threat: name it, state the property it violates, explain why it is realistic for your domain.
- Reference ATT&CK technique IDs where applicable.
- Sessions 3-7 give you the controls. A3 captures the threats that make those controls necessary.

Looking Ahead - Session 3: Cryptography



- You now know what you are defending against: a threat landscape shaped by actor motivation, attack surface, and six STRIDE categories.
- Session 3 asks: what do security controls actually achieve? Starting with cryptography - not the mathematics, but what it does at the property level.
- Every control in Sessions 3-7 exists because of a threat category you have now named.

S3: Cryptography - Properties, Not Mechanics. Bring your STRIDE and ATT&CK notes.

Questions & Discussion



Session 2 - NB5004CEM Cybersecurity



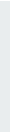
Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While every effort is made to keep the information accurate and up-to-date, no representations or warranties of any kind, express or implied, are made about the completeness, accuracy, reliability, suitability, or availability of the content.

This presentation may include references or links to third-party websites or content. No endorsement is made of views expressed or information provided on such external sites.

Any action you take upon the information presented is strictly at your own discretion. This disclaimer is subject to change without notice.



Images and artworks used in this presentation are used for general informational purposes only. The material is available in an effort to explain issues relevant to the topic. This constitutes fair use of any copyrighted material as it is educational in nature.

Last modified: 26 Jun 2026